
Leveraging Endpoint Data to Identify Behavioural Risks of Malware Encounters

by

Seleem Wagdy
(2771615)

Project supervisors: F. Massacci,
M. Zhang
J.A. Hartel
Project members: Seleem Wagdy

2025-08-25

Submitted in partial fulfillment of the requirements for
the **Bachelor of Science in Computer Science**

Leveraging Endpoint Data to Identify Behavioural Risks of Malware Encounters

Seleem Wagdy

Vrije Universiteit Amsterdam

Amsterdam, The Netherlands

s.a.wagdy@student.vu.nl

ABSTRACT

In today's threat landscape, malware exposure is driven by technical vulnerabilities as well as user behaviour. This research applies a case-control study on telemetry data collected by Northwave Cybersecurity, a European cybersecurity service provider based in The Netherlands, to identify behavioural patterns correlated with malware encounters. The results show that high browsing diversity has a significant effect, doubling the odds of exposure (2,00), while frequent night-time browsing (1,39) and visiting primarily unpopular websites (1,51) also considerably increase risk. Specific website categories also contribute: visiting adult websites can increase the odds by 1,34, cryptocurrency-related sites by 1,59, and malicious sites by 2,16. On the system side, installing highly diverse software can increase the odds by 1,69, while not installing OS updates presents a moderate increase of 1,18. Additionally, downloading media-related software raises the odds by 1,29, whereas piracy-related software doubles the risk (2,00). The accuracy of these odds may be affected by under-represented behaviours in the data. Customer-specific security policies, skewed device usage outside business hours, and technical limitations complicate the assessment of risky behaviours.

I. INTRODUCTION

In today's highly digitalised world, organisations of varying types are more exposed to malware threats than ever [1]. Modern malware is highly complex and deceptive, often resulting in severe reputational and financial consequences [2]. Incidents are commonly linked not only to technical vulnerabilities, but also to user behaviour [3]. Although a lot of research has focused on technical vulnerability management, the behavioural factors of malware exposure remains relatively unexplored [3]. Previous studies have shown that certain user behaviours may be associated with a higher risk of malware exposure [4]. In today's threat landscape, where malware campaigns often vary in tactics and scope [5], understanding the behavioural

factors that increase the likelihood of encountering malware is essential for both prevention and incident response [3].

This research applies a case-control study based on telemetry data collected by Northwave Cybersecurity, a European cybersecurity service provider based in The Netherlands. Using a dataset of around 86,000 endpoints and following the methodology outlined by M. Meschini, G. D. Tizio, M. Balduzzi and F. Massacci in [6], the analysis examines how different behaviours, both on the system and the network-level, correlate with the likelihood of malware encounters within organisations. The methods and findings provide practical insights for organisations looking to monitor behavioural risks and reduce their overall exposure to malware threats.

II. PROBLEM DESCRIPTION AND RESEARCH QUESTIONS

2.1 Problem Description

This research addresses the problem of user behaviour as a critical factor in malware encounters. While traditional approaches to cybersecurity focus on patching, vulnerability management, and automated defences [7], real-world compromise often depends on user actions: clicking a link, visiting a website, or downloading unverified software [8].

The challenge is that existing predictive frameworks (e.g. exploit prediction scoring systems) rely almost exclusively on technical indicators and neglect the human behavioural aspect. By investigating which behaviours most frequently contribute to malware encounters, this work aims to improve the predictive power of existing models, extend the scope of monitoring systems, and provide organisations with applicable insights.

The results of this research are useful for:

- Designing user-focused defence strategies such as policy adjustments, adaptive warnings, or security awareness trainings.
- Enhancing threat prediction and security monitoring systems by incorporating behavioural data alongside technical vulnerability metrics.

2.2 State of The Art

The role of human behaviour in malware encounters has been recognised but remains insufficiently represented in practice [3]. Research on phishing, social engineering, and risky browsing shows that users are often the weakest link in security [9], but most large-scale predictive systems are still designed around vulnerabilities and exploits rather than end-user actions [10].

This makes the problem obscure for two reasons:

1. Behaviour is complex and contextual: influenced by cognitive biases, risk perception, organisational culture, and workload.
2. Data is inconsistent: OS-level policies, logging limitations, and vendor differences make it difficult to retrieve consistent behavioural data.

Despite these challenges, existing research confirms that a behavioural layer of risk exists and can be studied [3], [4]. Table 1 presents the properties of interest and their relevance to this study.

2.3 Unique Value Contribution

The unique value contribution of this project lies in integrating behavioural aspects into malware encounter analysis and developing the technical solutions required to measure them. Instead of focusing only on technical vulnerabilities, this study explores the extent to which user actions contribute to malware exposure. By gaining insight into employee behaviours, organisations can monitor human risk using behavioural metrics and implement corrective measures more effectively. The technical challenge lies in extracting relevant behavioural and malware data within Northwave’s extensive datasets and finding correlations between

behavioural patterns and malware encounters. This process involves identifying data sources, filtering irrelevant data, developing data retrieval solutions, and leveraging statistical methods to provide practical results.

We address the following research questions:

- **RQ1:** To what extent does user behaviour influence the odds of encountering malware in organisational environments?
- **RQ2:** How do system and network activities correlate with increased malware exposure?

III. DATASET

3.1 Data Sources

When identifying data sources, the following criteria is applied:

- Provides data on endpoint user behaviour.
- Provides data on malware encounters.
- Provides characteristics of the customer associated with the endpoint.

This data is provided by Microsoft Defender, an antivirus software for monitoring and protecting endpoints from threats, and Microsoft Sentinel, a Security Information and Event Management (SIEM) platform designed to analyse security data from many different sources. Additionally, Medusa, an in-house application developed by Northwave, is used to aggregate the data from both Defender and Sentinel. Within Medusa, specific data tables are queried from both applications, which are chosen depending on the desired information. Customer characteristics (region, industry, and size) are retrieved from Northwave’s internal documentation.

Table 2: Data Sources

Source	Endpoint Behaviour	Malware Encounters	Customer Characteristics
Defender	✓		
Sentinel		✓	
Medusa	✓	✓	
Northwave Documentation			✓

Table 1: Properties of Interest from State of the Art

Property	Description	Relevance	Example Reference
P1: Technical focus	Most scoring systems (e.g. EPSS) rely only on vulnerability/exploit data.	Missing behavioural aspect.	Moustafa AA, Bello A, and Maurushat A. emphasise integrating behavioural sciences into cybersecurity strategy in [11].
P2: Risk perception	Users underestimate threats when visiting websites or downloading software.	Behaviour influences malware exposure.	Krishnan, S. describes how human curiosity is exploited by malware attacks in [12].
P3: OS constraints	Endpoint data varies across Windows, Linux, and macOS.	Data aggregation and analysis challenges.	Kyle Avery shows how telemetry data collection varies significantly by OS in [13].

3.2 Data Cleaning and Collection

A. Endpoint Dataset

To ensure the endpoint dataset is relevant and complete, the following is filtered out:

- Customers with emergency onboarding or incomplete software licensing
- Irrelevant device types (e.g. servers, network devices, audio/video devices etc.)
- Mobile and legacy operating systems (e.g. iOS, Android, Windows XP, Windows Vista etc.)
- Linux and macOS devices

First, customers with incomplete software licensing are excluded as their endpoint data is insufficient or unavailable. This includes customers with specific Northwave service offerings, such as emergency onboarded customers, without the correct log sources. Second, when sampling relevant customers, irrelevant device types such as Servers, Network, Communication, or Audio/Video devices are filtered out since they are not indicative of individual user behaviour. Third, devices running mobile or legacy operating systems are excluded because they are not fully supported by Defender or Sentinel, resulting in incomplete data. Finally, Linux and macOS devices are removed because of network and system policies that clash with the technical implementation methods (more details in section 6.1). In conclusion, the final dataset includes customers that are fully onboarded with complete licensing and data collected from workstations running Windows 11 or Windows 10. Details on the data collected and cleaned from these devices are the Technical Solution section (IV).

B. Malware Encounter Dataset

To collect cases for the malware encounter dataset, we observe the last 2 weeks of malware alerts from relevant customers, apply the endpoint filters described above, as well as the following filters to the malware alerts themselves:

- Certificates blocked by customers
- Alerts concerning infected servers or mail abuse
- Unconfirmed malware reports
- Phishing reports
- Test alerts

First, alerts related to software certificate blocklists are removed, as they depend on customer-specific configurations, rarely involve malware, and don't have available details. Second, alerts concerning infected servers or mail abuse are ignored since they are not indicative of individual user behaviour. Finally, unconfirmed malware reports, phishing reports, and test alerts are filtered out as they are inconclusive. Although Northwave does not explicitly classify malware, the

final dataset includes all remaining malware encounters and potentially unwanted software (PUA), including trojans, coinminers, and malicious scripts.

C. Ethical Considerations

Given that this research involves data collected from real users, ethical sensitivity was a key consideration. To address privacy concerns, sensitive identifiers such as device names, IP addresses, or any information that could reveal the identity of users were excluded when constructing the datasets. Additionally, all data was queried in a secured environment with strict privilege controls, network encryption, and authentication requirements to ensure data protection.

3.3 Final Descriptive Statistics

After data cleaning, the final endpoint dataset consists of 85,945 devices from 80 customers across 8 industry sectors, primarily in The Netherlands but also in Germany, and one customer in Switzerland. Based on the United Nations (UN) classification for company sizes, these customers include 70 medium enterprises (50-249 employees) and 10 large (>250 employees). Additionally, the malware encounter subset consists of 336 endpoints from 44 customers across 8 industry sectors in the same regions, and of both medium and large sizes.

Chart 1: Customer Distribution by Industry Sector

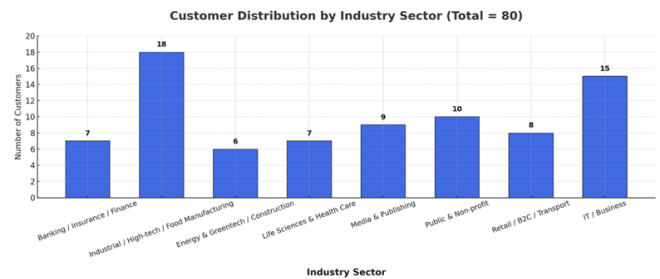


Table 3: Distribution of OS Version across Endpoints

OS	Endpoints	Malware Encounters
Windows 11	22,027	145
Windows 10	63,918	191
Total	85,945	336

IV. TECHNICAL SOLUTION

4.1 Architecture

Using queries in Medusa, the case, control, and random samples will be retrieved using the filters previously mentioned in section 3.2.

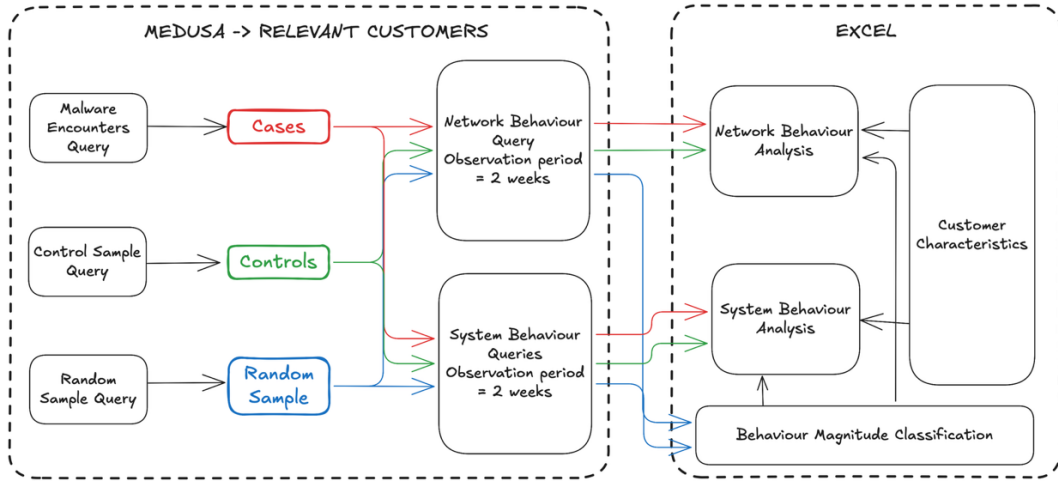


Diagram 1: Project Schematics

The following network and system-based behaviours will then be measured on all endpoints:

Network-based Behaviour:

- Categories of visited websites
- Diversity of visited websites (number of distinct categories)
- Unpopularity ratio of visited websites
- Night-time ratio of visited websites

System-based Behaviour:

- Categories of installed software
- Diversity of installed software (number of distinct categories)
- Not updating operating system

Next, all behavioural query results will be imported into Excel for analysis. Results from the random sample will be used to classify the magnitudes of behaviours with continuous variables i.e. diversity, unpopularity ratio, and night-time ratio. When analysing individual behaviours, the customer characteristics will be used to match each case to its corresponding controls. More details about the evaluation metrics used for analysis can be found in section 5.1.

4.2 Key Technical Functionalities

To measure behaviour, an observation period of 2 weeks was determined which, for cases, is adapted to the time frame before the first malware alert associated with each endpoint. This period was chosen to equally measure behaviour for all malware encounters in the last 2 weeks, as Defender only retains data for up to 30 days (28-day window). All endpoints for which we do not observe any behaviour during the observation period are filtered out.

A. Sample Size

When determining the sample size, we attempt to optimise the statistical power and accuracy of the analysis. Thus, we aim for a ratio of controls to cases of

3:1, i.e. for each case we retrieve 3 control endpoints, with a minimum ratio of 1:1. For the 336 malware encounters, this ratio would result in a sample size of 1008 endpoints. However, since the cases and controls need to be matched on characteristics, and ideally on all behaviour features except for the one being tested, we cannot expect every randomly chosen control to meet these criteria. Additionally, the technical methods do not detect all network or system behaviours which means not all endpoints sampled will exhibit measurable behaviour, further reducing the likelihood of a perfect match (more details in section 4.5). With these uncertainties in mind, a larger sample size is considered using a baseline formula with 3:1 ratio:

$$n = \frac{1008}{r}$$

with $r = 0.10$ for probability that at least one randomly chosen control matches the characteristics and behaviours of the case. Thus, we obtain a sample size of $n = 10,080$ endpoints.

B. Network-based Behaviour

Each visited website will be categorised based on its content with the following categories: Adult, AI, Piracy, Gaming, Gambling, Crypto, Social media, Entertainment, Malicious, and Unknown. “Entertainment” contains sites for streaming, music, e-books etc. while “Malicious” includes malware, ransomware, and phishing sites. “Unknown” contains all network activity, by the user and primarily by processes, that does not correspond to URL domain visits or fit into any other category. The categories will then be used to compute the diversity of website visits, and the individual site visits are used to compute both the unpopularity ratio and the night-time ratio.

C. System-based Behaviour

Similarly, each software product will be categorised based on its function, with the following categories:

Gaming, Gambling, Piracy, Media, Crypto, Suspicious, and Unknown. The category “Suspicious” includes software whose digital certificates have either been used to sign malware or have been swapped onto malicious executables. It is important to note that the presence of these certificates on malware does not mean that the issuing organisation has been compromised. In many cases, attackers simply attach publicly available or stolen certificates to malware. Moreover, the presence of a suspicious certificate does not indicate the presence of malware, but that the certificate is not necessarily valid. Examples of such misuse were given by ‘jkerail’ in [14]. The category “Unknown” includes all software that do not fit into any other category. Similarly, the categories are then used to compute the diversity of installs. Finally, we check whether the user installed the latest OS software updates on their device.

4.3 Technical Solutions

A. Control and Random Sample Queries

To retrieve the control and random samples for analysis, we first apply the endpoint filters (3.2 A) to our queries. For the control sample, we exclude all cases from the retrievable endpoints; and for the random sample, we exclude both cases and controls. The sample size is then divided by the number of customers, and the resulting number of endpoints are selected from each customer. This method is used because in Medusa, each query is run for all selected customers individually, rather than to the combined pool, which prevents a truly random sample.

B. Malware Encounters and Filter Queries

To retrieve the cases, we include the malware alert filters (section 3.2 B) to our query and extract the device ID from the alert entities. The ID is then used to identify distinct devices and retrieve the first alert associated with each device. This allows us to measure the behaviours within the relevant time frame i.e. 2 weeks before the first alert. Using a separate query, we then filter these devices according to the endpoint filters (section 3.2 A).

C. Network Behaviour Query

To detect and categorise website visits, we query remote URL visits against a categorised inventory of sites. The sites were compiled using categorised blocklists from two public GitHub repositories by ‘jkerail’ and ‘StevenBlack’ ([15] and [16] respectively), along with the most visited sites in The Netherlands and Europe for each category. For each URL, variations in top-level domains e.g. “.com”, “.net”, “.org” etc., as well as common sub-domains were added to ensure maximal detection. Next, the diversity of online activity is determined by the number of distinct categories associated with a user’s website visits. The category

“Unknown” is excluded from this sum as it primarily contains process activity. To determine the unpopularity ratio, we calculate the percentage of URLs visits that are not in the Tranco Top 10k list of most visited websites from August 2025. Similarly, activity in the “Unknown” category is excluded to conserve the metric’s accuracy. The night-time ratio of website visits is measured by calculating the percentage of visits between 7pm and 7am. Once again, activity in the “Unknown” category is excluded from this percentage.

D. System Behaviour Query

To categorise software products on endpoints, we extract the signatures from digital certificates associated with different applications and check if there is software signed by that vendor present on the endpoint. For vendors with a diverse range of software across multiple categories e.g. Apple or Microsoft, the executable’s file name is used in combination with the signature to identify the specific software product. Certificates were compiled using lists from a public GitHub repository by ‘jkerail’ [15], along with the most used applications in The Netherlands and Europe for each category. A Python script was used to parse and extract the signatures from these certificates. The diversity of software is determined by the number of distinct categories associated with a system’s software. The category “Unknown” is excluded from this sum since it contains a variety of user or preinstalled software and is present in every endpoint. To determine whether the user updated their OS, we check if the installed version matches the most recent build number (as of August 2025).

4.4 Meeting the Requirements

These technical solutions allow the retrieval of network and system-based behaviours for the samples, as well as the malware encounters, to analyse their correlation. The query outputs are simple and straightforward, which helps streamline data analysis and interpretation of results. Moreover, the queries can provide intuitive monitoring of user behaviour, which gives insight into an organisation’s security maturity and culture. By identifying vulnerability areas, organisations can implement targeted corrective measures and effectively manage human risk.

4.5 Failure Modes

A. Network Behaviour Query

A limitation of our network behaviour query is that it fits all network activity on the endpoint to a predefined inventory of websites. This means that it does not detect all site visits by the user and only approximates the categories and diversity of online activity, with limited coverage. This affects both the scope and accuracy of all

network-based behaviours and, consequently, the number of endpoints retrieved with measurable behaviour. To mitigate the reduced scope, the sample size was increased in an effort to retrieve more endpoints with measurable behaviour.

B. System Behaviour Query

As with the network behaviour query, the system behaviour query has limited coverage of software activity on endpoints due to the use of a predefined inventory of categorised software signatures. Similarly, this affects the measurement of system-based behaviours and, consequently, the number of endpoints retrieved with measurable behaviour. Once again, the sample size was increased to mitigate the limitations of this approach.

V. TECHNICAL EVALUATION

5.1 Evaluation metrics

A. Odds Ratio

The case-control study measures the strength of the association between the exposure to a risk and the outcome in terms of odds ratio. Here, the risk is a specific behaviour and the outcome is a malware encounter (Table 4).

Table 4: Contingency Table for Odds Ratio

	Encountered malware X	Not encountered malware X
Exposed Y	a	b
Not exposed Y	c	d

Endpoints that encountered malware represent the case group ($a + c$), while the control group consists of endpoints that did not encounter malware ($b + d$). The odds ratio is defined as the ratio between the odds of exposure among cases ($\frac{a}{c}$) and the odds of exposure among controls ($\frac{b}{d}$). A value greater than one indicates that the first event is more likely to occur than the second. For example, an odds ratio of 5 means that users exhibiting a specific behaviour are 5 times more likely to encounter malware than those who do not exhibit that behaviour. An odds ratio less than one indicates that the first event is less likely to occur than the second. Essentially, it suggests a negative association between the exposure and the outcome, or that the exposure is associated with a decreased likelihood of the outcome.

B. Behaviour Magnitude Classification

The following method was taken from M. Meschini, G. D. Tizio, M. Balduzzi and F. Massacci in [6]. Since some of the behaviours being tested are continuous variables rather than boolean (e.g. updating OS),

thresholds are required to classify their magnitudes based on distribution. These behaviours include the diversity, unpopularity ratio and night-time ratio. Each behaviour was split into three levels: *Nothing* (practically absent), *Something* (present), and *A lot* (in abundance). Thresholds were determined using bottom percentiles to define the *Something* level, and top quartiles of those values to define the *A lot* level. Thresholds were computed using all endpoints which exhibited the network or system behaviour being measured i.e. diversity ≥ 1 category, and available unpopularity ratio and night-time ratio. The impact of exposure is then tested in two phases: a first test between *Nothing* and *Something*, and a second test between *Something* and *A lot*.

5.2 Experimental Scenarios

Given that the diversity of software categories has a low range, only the *A lot* threshold was defined using the mean of the distribution. This is due to the system behaviour query not detecting enough certificates on systems, returning limited and largely uniform diversity. Percentiles were adjusted to reflect meaningful thresholds for each behaviour’s magnitude.

Table 5: Behaviour Magnitude Thresholds

Behaviour	<i>Something</i>	<i>A lot</i>
Website diversity	>1 category (bottom 20%)	>4 categories
Unpopularity ratio	>1% (bottom 35%)	>33%
Night-time ratio	>1% (bottom 30%)	>40%
Software diversity	-	>1

With these values in mind (Table 5), we plan to demonstrate the association between different behaviours and malware encounters, in terms of odds ratios. Specifically, we will test the effects of:

- Visiting adult, malicious, or cryptocurrency-related websites
- *Nothing* vs *Something* for website diversity
- *Something* vs *A lot* for website diversity
- *Nothing* vs *Something* for unpopularity ratio and night-time ratio of website visits
- *Something* vs *A lot* for unpopularity ratio and night-time ratio of website visits
- Installing media or piracy-related software
- *Nothing* vs *A lot* for mean diversity of software
- Not installing OS updates

5.3 Key Findings

When testing behaviours, the ideal case-control ratio of 3:1 was not achieved. In most cases, it was approximately 2,3:1. This is primarily explained by a large part of the cases coming from a customer with unique characteristics not found anywhere else in the customer pool. This imbalance can indicate differences in customer security maturity. Moreover, it can also be attributed to the lack of endpoints retrieved with detected behaviour, particularly during system behaviour tests, as endpoints with undetected behaviour were excluded from the analysis. Nevertheless, the ratios found are sufficient to preserve the validity of the results. All controls were matched to the characteristics of the cases and, where possible, on all behaviours except the one being tested. All values were rounded up or down to the nearest hundredth.

Accordingly, the key findings are as follows:

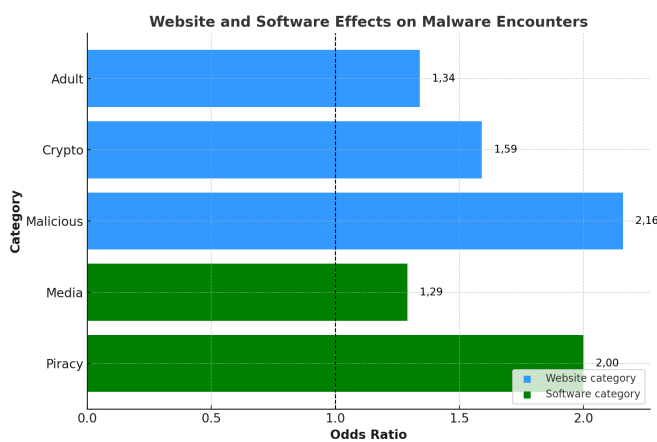


Chart 2: Website and Software Category effects on Malware Encounters

Visiting adult websites increases the odds of encountering malware by 1,34, while cryptocurrency-related sites present a higher risk with an increase to 1,59. As expected, visiting malicious sites has the greatest impact, more than doubling the odds (2,16). For software, downloading media-related applications increases the odds by 1,29, while piracy-related software is associated with a substantial 2,00 odds ratio.

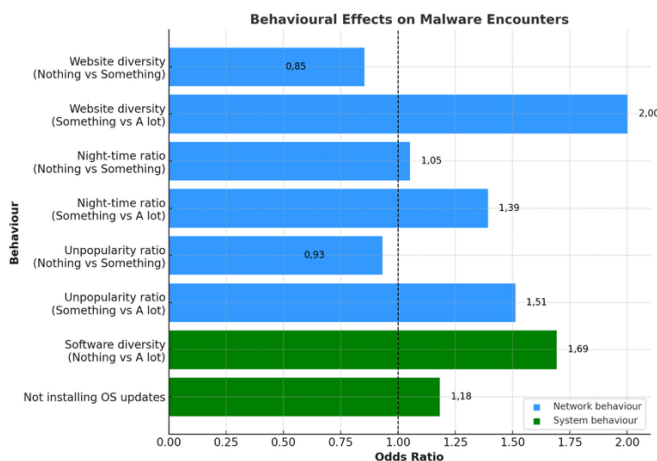


Chart 3: Behavioural Effects on Malware Encounters

Moderate website diversity shows a negative association with malware encounters, with an odds ratio of 0,85. In contrast, high website diversity has the strongest effect, doubling the odds (2,00) and indicating the need for organisations to restrict highly diverse online activity. A moderate night-time ratio presents a marginal increase (1,05), whereas frequent night-time browsing raises the odds to 1,39, suggesting that users are more vulnerable outside business hours. A moderate unpopularity ratio also shows a slight negative association with malware (0,93), while highly unpopular online activity significantly increases the odds (1,51), highlighting the importance of blocklists for obscure websites. For system behaviours, installing above-average diversity of software increases the odds by 1,69, indicating that organisations should limit highly diverse software installation. Finally, not installing OS updates presents a moderate increase, 1,18 times, a risk that could be mitigated through reminders or enforcing update policies.

It is important to note that the accuracy of certain values may be affected by several factors. First, the analysis is highly influenced by the security policies implemented by customers. Measures such as blocklists and restrictions on software installation can directly affect exhibited behaviours, and consequentially, influence the odds ratios. Second, most observed devices are intended for use during working hours, while some are used by remote employees outside local business hours, which has considerable effects on log timestamps. These factors are reflected in the odds ratios for night-time ratio, website or software diversity, and unpopularity ratio. Additionally, the limitations of the technical solutions (4.5) likely further influenced the results. As previously mentioned, the query constraints can lead to under-represented behaviour in the data which is compounded by the uneven distribution of cases across customers, causing the odds ratio to reflect more bias in the associations. These considerations are particularly important for values under 1, as they appear to indicate protective behaviour, even when this may not actually be the case.

VI. THREAT TO VALIDITY

6.1 Linux and macOS Devices

During the development of the behavioural query, we faced challenges related to data visibility on Linux and macOS devices. Network data on remote URL visits is limited because of OS policies and differences in how Defender integrates with these devices. Additionally, differences in software signing systems make it difficult to measure software behaviours because some signature metadata looks different or is incomplete. Details on how logging and telemetry data collection vary significantly for these devices were given by Kyle Avery on behalf of Outflank in [13]. Given these challenges, the time and effort necessary to overcome

them, and the fact that these devices represented a small portion of the final malware encounter dataset (21 cases), we decided to exclude them from the study.

6.2 Excluded Behaviour Metrics

When determining behaviours to measure, we initially attempted to detect all website visits and categorise them using an external website classification tool. This proved to be difficult because most of an endpoint's network activity is initiated by processes rather than directly by the user, and involves highly diverse remote URL visits, requiring rigorous filtering to isolate the relevant data. Therefore, the site inventory method, which is faster and more resource-efficient, was implemented.

The same approach was attempted to count individual software products and categorising them using an external software classification tool. However, this proved difficult due to the challenge of distinguishing which software was preinstalled and which was user-installed, information that is highly customer-specific. A file prevalence measurement was also attempted by counting the number of devices that contain a given file and dividing by the total number of devices in the pool. However, most files showed very low prevalence as the query was heavily affected by the limitations described in section 4.5 B. Thus, the metric was considered too inaccurate to be included in the study.

VII. CONTRIBUTIONS AND FEEDBACK

A. Individual Contributions

I developed and implemented all technical solutions to measure behaviours, including compiling the domain and certificate inventories and writing all the queries. I also undertook the technical evaluation and authored the paper. With the help of Maresa Vermulst, a detection engineer at Northwave, we collected and cleaned all customer, endpoint, and malware encounter data used in the final datasets. Maresa also inspired me to use the software certificate and website blocklist methods, and provided me with remarkable guidance and support throughout the entire project.

B. Expert Feedback

“The results in the thesis mostly match what I would expect based on real-world experience. The link between browsing diversity and malware exposure makes sense, as users who visit a wide range of websites are more likely to encounter risky content. The night-time browsing finding also fits with what we see, namely that people often use work devices for personal activities outside of work hours, which tends to be riskier. The results around unpopular websites and specific categories like adult or crypto-related sites

seem plausible. Although the crypto related findings are a bit harder to interpret, since it's not always clear whether the behaviour leads to infection or the other way around.

Software diversity is another familiar risk factor, especially in environments without strong technical controls. Overall, the results are logical and reflect patterns we often see in incident response.

The acknowledgement of limitations, for example the underrepresented behaviours and customer-specific policies shows a mature understanding of the challenges in behavioural data analysis and strengthens the credibility of the findings. Overall, the thesis offers valuable contributions to understanding user behaviour in cybersecurity contexts. It would be interesting to see how these findings could be translated into practical recommendations for improving endpoint protection and user awareness.”

– Maresa Vermulst, Detection Engineer at Northwave.

VIII. CONCLUSIONS AND WAY FORWARD

To conclude, the results summarised in Chart 2 and 3 show that both online and system-based behaviour can be strong indicators for malware encounters. Significant effects were observed for visiting adult, malicious, and cryptocurrency-related sites, as well as downloading piracy-related software. Comparable effects were found for high website diversity, high unpopularity ratio of sites visited and frequent night-time browsing. Installing media-related software and not updating the operating system presented more modest effects. By contrast, moderate website diversity and unpopularity ratio showed minor negative associations with malware encounters. However, the accuracy of these findings could be affected by under-represented behaviours in the data caused by several factors. These factors, including customer-specific security policies, skewed device usage outside of business hours, and limitations in the technical solutions, make it harder to accurately estimate the magnitudes of risky behaviours and their effects on malware encounters. The technical limitations could be addressed by using more advanced methods capable of detecting all online and system activity, categorising website visits and software installed dynamically, and thus compute the unpopularity and night-time ratios more accurately.

Nevertheless, the findings provide useful insight on which behaviours increase the odds of malware exposure, and highlight focus areas for organisations to mitigate human risk effectively. Moreover, the technical solutions offer a solid foundation for a behavioural monitoring system, which could be integrated into a dashboard to give organisations an overview of employee behaviour and associated risks. This would enable them to quickly assess levels of human risk and implement the necessary corrective measures. Future studies could expand on this work by examining

different behaviours such as downloading files from untrusted websites, clicking on links in emails, or using unapproved data-sharing methods, to gain more understanding of the human factors influencing malware exposure.

REFERENCES

- [1] Verma, Ritesh. (2024). CYBERSECURITY CHALLENGES IN THE ERA OF DIGITAL TRANSFORMATION. 10.25215/9392917848.20.
- [2] Jamie MacColl, Pia Hüsich, Gareth Mott, James Sullivan, Jason R. C. Nurse, Sarah Turner & Nandita Pattnaik (2024). *The Scourge of Ransomware: Victim Insights on Harms to Individuals, Organisations and Society*. RUSI Occasional Papers, Royal United Services Institute.
- [3] Fanny Lalonde Lévesque, Sonia Chiasson, Anil Somayaji, and José M. Fernandez. 2018. Technological and Human Factors of Malware Attacks: A Computer Security Clinical Trial Approach. ACM Trans. Priv. Secur. 21, 4, Article 18 (November 2018), 30 pages.
- [4] Mussa, Awad A Younis & Stronberg,, Elise & Noor, Shifa. (2021). User's Susceptibility Factors to Malware Attacks: A Systemic Literature Review. Vol:15. 12.
- [5] Recorded Future, "H1 2024: Malware and Vulnerability Trends Report," 10 September 2024. Online. Available: Recorded Future.
- [6] M. Meschini, G. D. Tizio, M. Balduzzi and F. Massacci, "A Case-Control Study to Measure Behavioral Risks of Malware Encounters in Organizations," in *IEEE Transactions on Information Forensics and Security*, vol. 19, pp. 9419-9432, 2024, doi: 10.1109/TIFS.2024.3456960. keywords: {Malware;Organizations;Ransomware;Market research;Cancer;Web sites;Standards organizations;Malware;case-control study;risk factors},
- [7] Waqas, M., Ruiz-Martinez, A., Villagrà, V. A., & López-Pajares, D. (2020). *Software security patch management — A systematic literature review of challenges, approaches, tools and practices*. arXiv preprint arXiv:2012.00544.
- [8] Sánchez-Rola, I., Balzarotti, D., Kruegel, C., Vigna, G., & Santos, I. (2020). *Dirty Clicks: A Study of the Usability and Security Implications of Click-related Behaviors on the Web*. In *Proceedings of The Web Conference 2020 (WWW '20)*. ACM.
- [9] RAND Corporation. (2015, October 7). *Social engineering explained: The human element in cyberattacks*. RAND Corporation Commentary.
- [10] Chowdhury, Rakibul & Prince, Nayem Uddin & Abdullah, Salman & Mim, Labonno. (2024). The role of predictive analytics in cybersecurity: Detecting and preventing threats. 10.30574/wjarr.2024.23.2.2494.
- [11] Moustafa AA, Bello A, Maurushat A. The Role of User Behaviour in Improving Cyber Security Management. Front Psychol. 2021 Jun 18;12:561011. doi: 10.3389/fpsyg.2021.561011. PMID: 34220596; PMCID: PMC8253569.
- [12] Krishnan, S. (2020). *Exploitation of Human Trust, Curiosity and Ignorance by Malware*. arXiv preprint.
- [13] Kyle Avery, Outflank blog, 2024, *EDR Internals for macOS and Linux*.
- [14] 'jkerai1', Github repository, 2025, *SoftwareCertificates / Manipulated Exes for Testing*.
- [15] 'jkerai1', Github repository, 2025, *SoftwareCertificates*.
- [16] 'StevenBlack', Github repository, 2025, *hosts*.